

Fabric Flo — Legal & Compliance Checklist for Operators

Document purpose: Practical checklist for launching Fabric Flo on the App Store, Google Play, and in production environments.

Important: This is **not legal advice**. Laws vary by country, state, and how you run the business (sole proprietor, LLC, union-affiliated service, etc.). **Consult a qualified attorney** licensed in your jurisdiction before relying on this list. Update your in-app Privacy Policy and Terms when your practices change.

Last updated: May 18, 2026

1. Before you launch (essential)

Task	Why it matters	Fabric Flo status
Business entity	Limits personal liability; needed for contracts and taxes	You must form/choose (LLC, corp, etc.)
Privacy Policy (public URL)	Required by Apple, Google, and most privacy laws	In-app <code>/privacy</code> — host same content at <code>VITE_PUBLIC_APP_URL/privacy</code>
Terms of Service	Sets rules with users; limits some liability	In-app <code>/terms</code>
User consent	Shows users agreed before account creation	Sign-up & sign-in checkbox in app
Account deletion	Required by Apple (since 2022) and good practice for GDPR/CCPA	In-app “Delete my account & cloud data” + email fallback
Support contact	Store listings and user trust	Set <code>VITE_SUPPORT_EMAIL</code>
Privacy contact	GDPR/CCPA requests	Set <code>VITE_PRIVACY_EMAIL</code>

HTTPS hosting	Protects passwords and inventory data in transit	Required for production
Supabase DPA / terms	You are a "controller"; Supabase is a "processor"	Accept Supabase DPA for EU/UK if applicable

2. App Store & Google Play disclosures

Apple App Privacy "nutrition labels"

Declare data types honestly. For Fabric Flo v1, typical declarations:

- **Contact info:** Email (account)
- **User content:** Inventory names, scan logs, locations (app functionality)
- **Identifiers:** User ID (account)
- **Usage data:** Optional only if you add analytics later
- **Camera:** Used for QR scanning — **not** stored as photos if you only decode QR in memory

State: data **not used for tracking** / **not sold** if true.

Google Play Data safety

Align with the same facts. Mark:

- Data collected: email, app activity (inventory/scans)
- Encrypted in transit: Yes
- Users can request deletion: Yes
- Optional: "Data is not required" for camera (app works with manual QR paste)

Reviewer notes

Provide a **demo account** (email/password) with a sample production. Explain camera is only for QR on the Scan tab.

3. Privacy laws (by region)

United States — California (CCPA/CPRA)

If you have California users and meet revenue/volume thresholds, you may need:

- “Do not sell or share” — Fabric Flo v1 should state you **do not sell** personal information
- Right to **know, delete, correct** — support via in-app deletion + `VITE_PRIVACY_EMAIL`
- Privacy Policy must describe categories collected and purposes

United States — other states

Virginia, Colorado, Connecticut, Utah, and others have similar consumer privacy laws. A lawyer can tell you if you meet “applicability” thresholds (often based on user count or revenue).

European Union / UK — GDPR

If you offer the app to EU/UK crew or process their data:

Requirement	Action
Lawful basis	Usually contract (providing the app) or legitimate interest (inventory tracking) — document in Privacy Policy
Transparency	Privacy Policy in plain language
Data subject rights	Access, erasure, portability, restriction — process via privacy email within ~30 days
Processor agreement	Supabase DPA; document sub-processors
International transfers	If US-hosted Supabase, mention transfer mechanisms (SCCs via Supabase)
DPO	Only if required (large-scale processing) — ask counsel
Records of processing	Internal spreadsheet: what data, why, retention, who accesses

Canada — PIPEDA

Similar themes: consent, access, deletion, security safeguards.

4. Employment & “crew data” (film/TV context)

Fabric Flo often holds **work-related** data (who scanned what, where gear moved). Consider:

Topic	Guidance
Who is the “data controller”?	Usually the production company or department using the app — if you sell Fabric Flo as SaaS, you may be controller or joint controller; clarify in Terms
Crew emails for invites	Department heads should only invite people with a work-related need ; don't use personal emails without permission
Union / studio rules	Some productions restrict apps that store movement of assets — check with production legal
Retention	Policy should say how long scan logs are kept (e.g. until production wraps + X months)
PIN vs real access control	PIN is convenience only; document that roles/invites are the real gate

5. Contracts & policies you may still need

Document	When you need it
Terms of Service (customized)	Have counsel review in-app Terms for your entity name, governing law, arbitration, limitation of liability
Privacy Policy (customized)	Same — add your legal name, address, effective date
Data Processing Agreement (DPA)	If a studio hires you and you process their inventory data on their behalf
Business Associate Agreement (BAA)	Only if you handle HIPAA health data — Fabric Flo normally does not
End User License Agreement (EULA)	Apple sometimes accepts Terms URL; optional separate EULA
Acceptable Use Policy	If you fear misuse (spam invites, illegal content)
Cookie / analytics policy	Only if you add Google Analytics, Sentry with cookies, etc.
Work-for-hire / crew notices	If production legal requires notice that scan data is logged

6. Intellectual property

Item	Action
"Fabric Flo" name	USPTO trademark search; consider federal registration
Logo	Ensure you own or license artwork
Open-source licenses	Keep <code>npm</code> dependency notices (MIT, etc.) — some stores want "Open Source Licenses" screen
Third-party QR libraries	Comply with <code>html5-qrcode</code> , <code>qrcode</code> licenses (generally permissive)

7. Security & incidents (operational law)

Task	Notes
Security practices	RLS on Supabase, HTTPS, strong passwords, no secrets in git
Breach response plan	If unauthorized access: contain, notify users/affected productions, notify regulators if required (GDPR 72h in some cases)
Logging	Don't log raw QR payloads in public analytics tools
Backups	Supabase backup policy documented

8. Payments & tax (if you charge)

Topic	Notes
Sales tax / VAT	Depends on where you sell subscriptions
Apple/Google IAP	If selling in-app subscriptions , Apple/Google take cut; may need their billing
B2B invoicing	Many production tools bill studios directly (outside stores) — simpler for B2B
Refund policy	State in Terms

9. Insurance (recommended, not always legally mandatory)

- **General liability** — business operations
 - **Cyber liability / E&O** — data breach, software errors affecting clients
 - Ask a broker familiar with **SaaS** or **entertainment production** tools
-

10. Children

Fabric Flo is a **workplace** tool. Privacy Policy states it is **not directed at children under 13** (or 16 in some EU countries). Do not knowingly collect children's data.

11. What Fabric Flo already implements (technical)

- In-app Privacy Policy and Terms
- Consent on sign-up and sign-in
- Delete data on device
- Delete cloud account RPC (`fabric_flo_delete_my_account` , migration 008)
- Row Level Security on Supabase (when migrations applied)
- Scan idempotency for flaky networks
- Offline-friendly local storage + sync when online
- No advertising trackers in v1

Still your responsibility: hosting public policy URLs, running migration 008, optional Edge Function to delete `auth.users` , honest store questionnaires, and counsel review.

12. Suggested timeline

Phase	Actions
Now	Lawyer review of Terms/Privacy; set production <code>.env</code> ; run migrations 001–008
Pre–TestFlight	Public HTTPS privacy URL; demo account; camera permission strings in native projects

Beta	Test account deletion, invites, offline sync; fix Privacy Policy gaps counsel identifies
Submit	Complete Apple/Google data forms; age rating 4+; support URL live
Post-launch	Process privacy emails within 30 days; document breaches; review policy yearly

13. Questions to bring to your attorney

1. Are we a **controller, processor, or joint controller** when a production uses Fabric Flo?
2. Do we need a **DPA** with each production client?
3. What **governing law and venue** should Terms use (your home state)?
4. Are we subject to **CCPA** or **GDPR** at our current user scale?
5. Do we need **workers' privacy notices** for union crews?
6. How do we complete **auth.users** deletion after our RPC (Edge Function vs manual)?
7. Any **IATSE / studio** contractual restrictions on tracking rental inventory digitally?

Contact placeholders (fill in before publishing)

Role	Email
Support	VITE_SUPPORT_EMAIL
Privacy / deletion requests	VITE_PRIVACY_EMAIL
Legal entity name	_____
Postal address	_____

End of checklist — retain a copy for your records and update when laws or product features change.